

خطة تطوير وتحول رقمي

تحويل منصة التذاكر إلى منتج SaaS احترافي للقطاع الصحي

خارطة طريق متكاملة لتطوير وإكمال وإصلاح منصة إدارة التذاكر والدعم، وتحويلها من نظام داخلي أحادي المؤسسة إلى منتج سحابي متعدد المؤسسات، جاهز للتسويق للمستشفيات والمؤسسات مع امثال صحي كامل.

جاهزية للتسويق

تعزيز أمني شامل

امثال صحي HIPAA-Grade

SaaS متعدد المؤسسات

الملخص التنفيذي والقرار الاستراتيجي

المنصة الحالية نظام تذاكر ودعم داخلي ناضج تقنياً مبني على NestJS + React 19 + PostgreSQL، صُمم لمؤسسة واحدة. البنية سليمة، والأمان المحيطي جيد، والميزات غنية – لكن لتحويله إلى منتج يُسوّق للمستشفيات تنقصه ثلاث ركائز غير موجودة اليوم.

2

لغة (AR/EN)

13

موديول وظيفي

+30

جدول بيانات

67

ملف باك-إند

الركائز الثلاث الناقصة

3 الطبقة التجارية

لا صفحة تسويقية، ولا تسجيل ذاتي، ولا اشتراكات/فوترة، ولا إدارة حسابات مؤسسية.

2 الامتثال الصحي

لا تشفير للبيانات الحساسة، ولا سجل تدقيق محكم، ولا سياسات احتفاظ – متطلبات إلزامية للمستشفيات.

1 عزل المؤسسات

المنصة أحادية المستأجر بالكامل – لا يوجد مفهوم «مؤسسة/مستشفى» في قاعدة البيانات. العزل بالكود على مستوى القسم فقط.

القرار الاستراتيجي المعتمد

البُعد	القرار	الأثر
نموذج التشغيل	SaaS متعدد المؤسسات (Multi-Tenant)	نشر واحد يخدم كل المستشفيات مع عزل كامل – الأمثل للتسويق والتوسع
الامتثال	كامل (HIPAA-Grade)	تشفير + تدقيق محكم + احتفاظ – يفتح باب المستشفيات الكبيرة والحكومية
التقنية	الإبقاء على NestJS + React	لا إعادة كتابة – البناء على الأصول القائمة وتوفير أشهر عمل
الأولوية	خطة + بدء فوري بالإصلاحات الحرجة	مسارات متوازية: إصلاح أمني الآن + تحوّل معماري بالتوازي

المسار الحرج نحو أول مستشفى قابل للبيع (MVP تجاري): 4-6 أشهر بفريق مركّز – مع بدء الإصلاحات الأمنية فوراً بالتوازي مع التخطيط.

نقاط القوة – نبني عليها ولا نلمسها

تقييم مباشر للكود (لا اعتماد على تقارير سابقة) كشف أساساً هندسياً متيناً يستحق البناء عليه بدل إعادة الكتابة:

المجال	التقييم
المعمارية	NestJS modular نظيف، فصل واضح للمسؤوليات، Prisma بفهرسة مدروسة حسب أنماط الاستعلام الفعلية
دورة حياة التذكرة	آلة حالات (State Machine) موثقة تفرض تأكيد المُنشئ قبل الإغلاق – من أفضل ما في الكود
الأمان المحيطي	JWT fail-fast · bcrypt cost 12 · قفل الحساب (5 محاولات/15 دقيقة) · CORS · HSTS · CSP + Helmet · CSRF · Throttler · allowlist بـ 6 طبقات
رفع الملفات	فحص الامتداد + MIME + magic-byte + منع path-traversal + حد 5MB (دفاع متعدد الطبقات)
Real-time	Socket.IO مع Redis adapter · إدارة اتصال صحيحة · rate limiting لكل حدث
RBAC	ثلاث طبقات: دور المستخدم ← صلاحيات القسم ← تجاوزات لكل مستخدم (13 صلاحية دقيقة)
الواجهة (UI)	تصميم متماسك · Dark mode · ثنائي اللغة React Query · responsive · RTL + AR/EN
التوثيق	توثيق ضخم: 54 ER diagram · endpoint · أدلة لكل دور · تقارير تدقيق

حقيقة مُتحقق منها: الباك-إند يُبنى بنجاح (اختبار مباشر – exit 0)، وجزم zod و csrf-csrf موجودة، ادعاء «ال build مكسور» في أحد التقارير السابقة **غير صحيح** – وهذا يؤكد أهمية التحقق المباشر قبل أي قرار.

الخلاصة

النظام **مبني جيداً في جوهره**: ما يفصله عن الاحترافية التجارية ليس عيوباً معمارية بل **إضافات وميزات ناقصة** – وهذا يجعل الاستثمار في التطوير أعلى عائداً بكثير من إعادة البناء من الصفر.

الفجوات الحرجة – المعمارية والامتثال

بنية النظام

لا Row-Level Security لا حماية على مستوى قاعدة البيانات ضد تسرب البيانات بين المؤسسات – دفاع واحد فقط بدل طبقات.	أحادي المستأجر بالكامل لا يوجد كيان Organization/Tenant. العزل بالكود على مستوى القسم فقط – أخطر عائق أمام تسويق المنصة لعدة مستشفيات.
خدمة ضخمة (God Service) <code>tickets.service.ts</code> يتجاوز 1000 سطر – دين تقني يصعب الصيانة والتوسع.	توجيه الواجهة يدوي <code>App.tsx</code> يستخدم <code>useState</code> بدل <code>react-router</code> (متبث وغير مُستخدم) – لا روابط عميقة ولا حماية مسارات حقيقية.

الجاهزية الصحية (Healthcare / HIPAA) امتثال

سجل تدقيق غير محكم أعمدة <code>ipAddress/userAgent</code> موجودة لكن لا تملأ أبداً؛ الكتابة يدوية متناثرة وغير <code>tamper-evident</code>.	لا تشفير للبيانات الحساسة الأسماء والهواتف والملاحظات (PHI/PII) مخزنة نصاً صريحاً – غير مقبول لبيانات المرضى.
لا احتفاظ ولا نسخ احتياطي لا سياسات <code>retention/erasure</code>. لا نسخ احتياطي أو DR في الريبو – متطلبات امتثال أساسية.	تخزين ملفات محلي غير مشفر لا <code>S3/object storage</code>. لا فحص فيروسات، لا تشفير – مشكلة كبيرة لبيانات المرضى وقابلية التوسع.

الأثر: هاتان المجموعتان تمثلان **بؤابة الدخول للقطاع الصحي** – لا يمكن التعاقد مع مستشفى دون عزل مؤسسات موثوق وضوابط حماية بيانات المرضى.

03 · ما الذي ينقص

الفجوات الحرجة – الأمان والمنتج والجودة

أولوية فورية **أمان**

الخروج لا يُبطل التوكن

refresh token صالح 7 أيام حتى بعد الخروج – لا blacklist ولا rotation.
نافذة خطر عند سرقة التوكن.

تحقق مدخلات ناقص

التحقق (Zod) على endpoint واحد من ~54: الباقي any: body –
سطح هجوم واسع.

تسريب صلاحيات بالتحليلات

getDepartmentPerformance () يتجاهل معاملاته فالمشرف يرى كل الأقسام.

لا إدارة ذاتية لكلمة المرور

لا endpoint لتغيير/استرجاع كلمة المرور رغم وجود flag
.forcePasswordChange

الطبقة التجارية **منتج**

لا صفحة هبوط/تسويق ولا تسجيل ذاتي ولا onboarding

لا اشتراكات/فوترة/خطط ولا إدارة حساب مؤسسي

لا بريد إلكتروني/SMS (إشعارات push فقط) – ضروري للتنبيهات والاسترجاع

الدَّين التقني **جودة**

صفر اختبارات فعلية رغم تهيئة Vitest كاملة

any منتشر (~146 frontend / ~107 backend) + strict:false

لا CI/CD ولا ESLint/Prettier ولا logging مُهيكل ولا metrics/APM

تنبيه أمني مُصلَح بالفعل: كانت هناك أسرار مكتوبة داخل docker-compose.yml (كلمة مرور DB + أسرار JWT). تم إخراجها إلى env. وإنشاء env.example. كجزء من الإصلاحات الفورية (المرحلة 0).

خارطة الطريق - نظرة عامة

ست مراحل متوازية جزئياً. تبدأ المرحلة 0 (الأمان) فوراً بالتوازي مع 1 و2 لتقصير الزمن للسوق.



أسبوعان · يبدأ فوراً		0 تثبيت والأمان الفوري – Stabilize & Secure
✓	إخراج الأسرار من <code>.env + .env.example</code> ← <code>docker-compose</code>	✓
✓	إصلاح تسريب صلاحيات <code>getDepartmentPerformance()</code>	✓
✓	إبطال refresh token عند الخروج (<code>blacklist + rotation + jwt</code>)	✓
✓	التقاط IP/UserAgent في كل كتابات التدقيق	✓
✓	تطبيق Zod validation على كل الـ <code>mutation endpoints</code>	✓
✓	إعداد CI/CD (<code>lint + test + build</code>) + ESLint/Prettier	✓
✓	تغيير/استرجاع كلمة المرور ذاتياً + تفعيل <code>forcePasswordChange</code>	✓
✓	تفعيل <code>strict</code> تدريجياً + حذف الكود الميت	✓

الهدف: إغلاق كل الثغرات الأمنية الحرجة وتأسيس بوابات الجودة قبل أي توسع معماري – أساس نظيف نبني عليه بقية المراحل.

المرحلتان 1 و 2 – التحوّل الأساسي

6-4 أسابيع

1 التحوّل متعدد المؤسسات – Multi-Tenancy

الهدف: كل مؤسسة معزولة تماماً: نشر واحد يخدم الجميع.

- نموذج **Organization** + العضويات + خطة/حالة الاشتراك
- إضافة organizationId لكل الجداول + Migration + backfill
- حلّ المستأجر: subdomain و/أو claim في JWT
- **Prisma extension** يحقن tenantId تلقائياً بكل استعلام
- **PostgreSQL RLS** كطبقة دفاع ثانية على مستوى القاعدة
- فصل Platform Admin عن Tenant Admin + onboarding + **اختبارات عزل صارمة**

6-4 أسابيع

2 الامتثال الصحي – Healthcare & HIPAA

الهدف: جاهزية للتعامل مع بيانات المستشفيات ومعلومات المرضى.

- **تشفير الحقول الحساسة** Prisma middleware عبر at rest (PHI/PII)
- **سجل تدقيق محكم**: append-only + hash-chain + IP/UA/tenant
- سياسات الاحتفاظ والحذف (retention & erasure) + مهام cron
- انتهاء الجلسة بالخمول + إعادة مصادقة للعمليات الحساسة
- **تخزين آمن**: S3/MinIO + تشفير + URLs موقّعة + فحص فيروسات (ClamAV)
- نسخ احتياطي مشفّر آلي + خطة DR موثّقة واختبار استعادة
- ميزات طبية: تصنيفات/أولويات، حقول مخصّصة، قوالب تذاكر
- (متقدم) خطاف تكامل **HL7/FHIR** مع أنظمة HIS/EMR + ورقة امتثال

ترتيب مقصود: المرحلة 1 تُنشئ حدود المؤسسة، والمرحلة 2 تحمي البيانات داخل تلك الحدود – لا معنى للتشفير والتدقيق دون عزل موثوق أولاً.

المراحل 3 و4 و5 – المنتج والجودة والإطلاق

3	SaaS Productization – المنتج التجاري	6-4 أسابيع
■	إعادة بناء التوجيه بـ react-router (روابط + حماية مسارات)	■ الفوترة والاشتراكات (Stripe/Paddle): خطط, حدود, تجربة, فواتير
■	صفحة هبوط/تسويق احترافية ثنائية اللغة	■ إدارة الحساب + العلامة التجارية لكل مؤسسة (white-label)
■	تسجيل ذاتي + Onboarding + تأكيد بريد + معالج بدء	■ البريد و SMS (SendGrid/SES + Twilio) للتنبيهات والاسترجاع
4	Quality & Observability – الجودة والمراقبة	مستمر / بالتوازي
■	اختبارات: E2E (Playwright) + frontend + backend + عزل المؤسسات	■ Metrics + APM (OpenTelemetry) + لوحات مراقبة
■	رفع التغطية نحو 80% وفرضها في CI	■ Health liveness/readiness + Redis/queue + تنبيهات
■	Logging مُهيكل (pino) + correlation IDs + tenant context	■ الأداء + الوصولية (WCAG) + تنظيف الدَّين التقني
5	التمكين التسويقي والإطلاق – Go-To-Market	3-2 أسابيع
■	بيئة عرض/تجربة (Demo/Sandbox) ببيانات مستشفى واقعية	■ بنية سحابية (IaC) + نشر إنتاجي + مراقبة + SLA/uptime
■	مواد تسويقية: عروض, دراسات حالة, ورقة أمان, مقارنة منافسين	■ توثيق العميل + مركز مساعدة + قياس النجاح (تفعيل/احتفاظ/CSAT)

الإصلاحات الحرجة الفورية والبنية المستهدفة

الإصلاحات الحرجة (تبدأ الآن – معظمها ساعات لا أسابيع)

#	الإصلاح	الموضع	الأولوية
1	إخراج الأسرار من docker-compose + .env.example	docker-compose.yml	مُنَجَز ✓
2	إبطال refresh token عند الخروج (blacklist + rotation)	auth.service.ts	فوري
3	Zod validation لكل endpoints	كل controllers	عالي
4	تغيير/استرجاع كلمة المرور ذاتياً	auth.* + واجهة	عالي
5	إصلاح تسريب getDepartmentPerformance ()	analytics.service.ts	متوسط
6	التقاط IP/UserAgent في التدقيق	mutation-logger	متوسط
7	CI/CD + ESLint/Prettier	github/workflows.	متوسط
8	حذف الكود الميت + strict TS تدريجي	متعدد	منخفض

البنية المستهدفة (Target Architecture)

عام	صفحة هبوط · تسجيل ذاتي · تسويق (react-router)
تطبيق	تطبيق المؤسسة لكل subdomain · لوحة إدارة المنصة (Platform Admin)
API	NestJS · Tenant Middleware ← RLS ← Prisma extension · Auth (jti + rotation + blacklist) · Billing · Email/SMS · Encryption
بيانات	PostgreSQL (RLS + tenantId) · Redis · S3/MinIO (تشفير + فحص فيروسات)
مراقبة	OpenTelemetry · pino · Metrics · Health checks

المخاطر والجدول الزمني والفريق

المخاطر والتخفيف

الخطر	التخفيف
تسرّب بيانات بين المؤسسات (الأخطر)	دفاع متعدد الطبقات: RLS + Prisma extension + اختبارات عزل آلية في CI
الامتثال الصحي معقّد وطويل	البدء بالضوابط التقنية الأساسية، والامتثال القانوني/BAA بالتوازي مع مستشار
تعطّل الميزات الحالية أثناء التحوّل	فروع منفصلة + اختبارات + نشر تدريجي عبر feature flags
زحف النطاق (Scope Creep)	التزام صارم بترتيب المراحل: MVP قابل للبيع أولاً ثم التوسّع
الأداء تحت الحمل متعدد المؤسسات	فهرسة على organizationId + caching + اختبار حمل

الفريق المقترح

الجدول الزمني

المرحلة	المدة	
0 – أمان وتثبيت	أسبوعان	2 مطوّر (NestJS/Prisma) Backend
1 – Multi-tenancy	4-6 أسابيع	1-2 مطوّر (React) Frontend
2 – امتثال صحي	4-6 أسابيع	1 DevOps/أمان (دوام جزئي)
3 – طبقة SaaS	4-6 أسابيع	1 ضمان جودة (QA)
4 – جودة/مراقبة	مستمر	مستشار امتثال صحي (استشاري)
5 – إطلاق	2-3 أسابيع	

الزمن للسوق: 4-6 أشهر لأول مستشفى قابل للبيع.

مؤشرات النجاح والخطوة التالية

مؤشرات النجاح

تجاري	منتج	تقني
أول مستشفى تجريبي	onboarding < 15 دقيقة	تغطية ≤ 80%
أول عميل مدفوع	uptime ≥ 99.9%	صفر ثغرات حرجية
CSAT مرتفع		عزل 100% في الاختبارات

الخطوة التالية الفورية

- ✓ اعتماد هذه الخطة وترتيب الأولويات
- ✓ البدء بالمرحلة 0 (الإصلاحات الأمنية) – **جارٍ التنفيذ فعلياً**
- ✓ تصميم نموذج بيانات المؤسسات (Multi-tenancy Schema) للمراجعة قبل Migration

NuzulTech حلول برمجية احترافية للمؤسسات

N

نحو الأنظمة الداخلية إلى
منتجات سحابية احترافية جاهزة للسوق.

هذه الوثيقة خارطة طريق قابلة للتنفيذ، مبنية على تحليل مباشر للكود وتدقيق مستقل للتقارير القائمة – لا افتراضات. كل مرحلة قابلة للقياس والمتابعة، مع بدء الإصلاحات الحرجة فوراً.